TECHNICAL DETAIL

Title	Information Disclosure via Detailed Database Error Messages
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/catalogue/store
Severity	**Low**
CVSS Score	**4.3**
Proof of Concepts	Please see Steps to Reproduce section

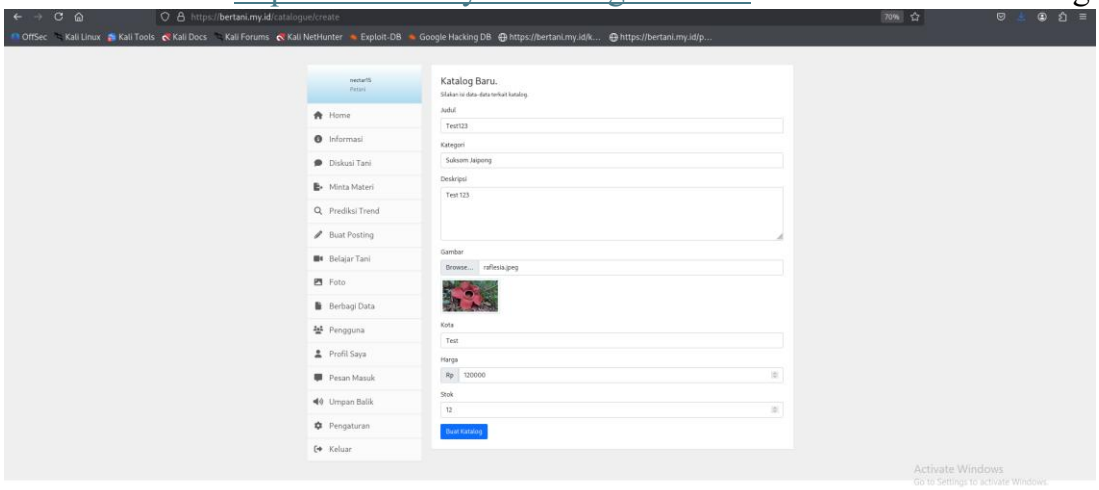
SUMMARY

Ditemukan kerentanan Information Disclosure (Pengungkapan Informasi) pada fungsi pembuatan katalog. Aplikasi memaparkan pesan kesalahan database yang sangat detail kepada pengguna ketika terjadi kegagalan *input*. Informasi yang bocor mencakup struktur *query* SQL, nama tabel, nama kolom, hingga teknologi database yang digunakan (MySQL).

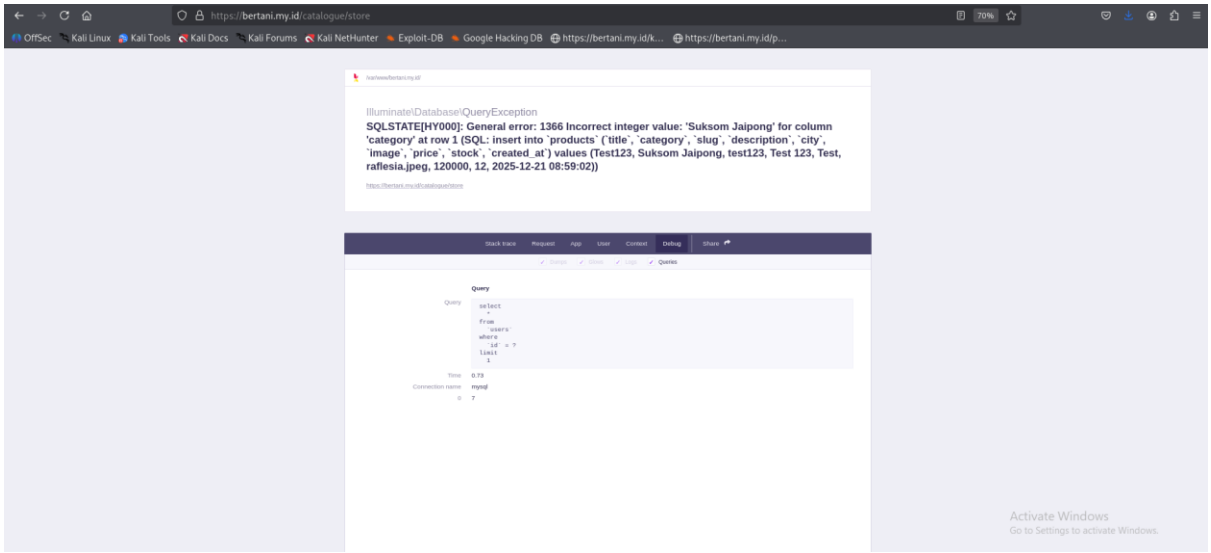
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai user di URL https://bertani.my.id/login

2. Masuk Ke URL https://bertani.my.id/catalogue/create lalu isi dan buat katalog



3. Lalu akan menampilkan informasi kolom category dan database menggunakan mysql



EXPECTED RESULT

Sistem seharusnya memiliki mekanisme penanganan kesalahan (*error handling*) yang generik untuk pengguna publik. Jika terjadi kegagalan pada database, aplikasi cukup menampilkan pesan kesalahan umum (seperti *"Terjadi kesalahan pada sistem, silakan coba lagi"*) tanpa mengungkapkan informasi teknis internal seperti nama tabel, kolom, atau struktur *query* SQL.

ACTUAL RESULT

Aplikasi menampilkan pesan kesalahan teknis yang sangat detail dari *framework* (Laravel/Illuminate) dan database (MySQL) langsung ke layar pengguna. Informasi ini mencakup struktur tabel products, kolom-kolomnya (title, category, slug, dll.), serta informasi *environment* server yang seharusnya hanya dapat diakses oleh administrator atau pengembang di lingkungan *development*.

IMPACT

- Information Leakage: Memudahkan penyerang untuk memahami skema database internal.
- Reconnaissance: Penyerang dapat menggunakan detail kolom dan tabel ini untuk menyusun serangan *SQL Injection* yang lebih akurat dan terarah.
- Security Weakness: Menunjukkan bahwa konfigurasi aplikasi masih dalam mode *debug* atau tidak memiliki penanganan *exception* yang aman untuk lingkungan produksi.

RECOMMENDATION

Custom Error Pages: Implementasikan halaman *error* kustom (misalnya halaman 500) yang hanya menampilkan pesan ramah pengguna tanpa detail teknis.

REFERENCES

1. CWE-209: Generation of Error Message Containing Sensitive Information: https://cwe.mitre.org/data/definitions/209.html
2. Laravel Documentation - Error Handling: https://laravel.com/docs/master/errors#configuration